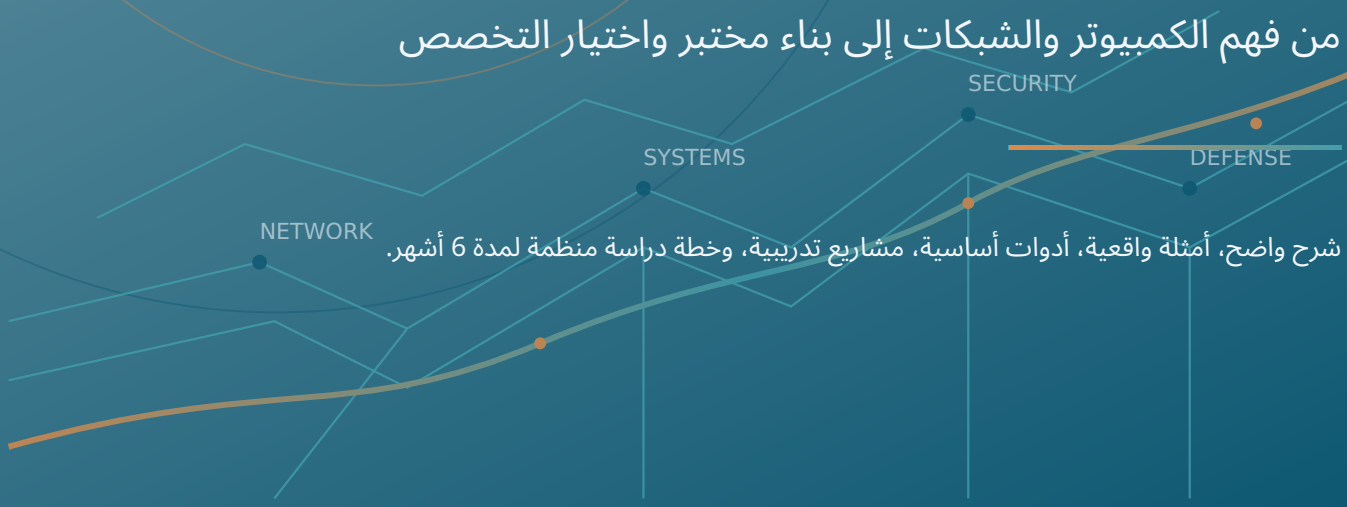
ZERO TO FOUNDATIONS · 2026 EDITION

أساسيات الأمن السيبراني

دليل عملي شامل للطالب الجديد
من فهم الكمبيوتر والشبكات إلى بناء مختبر واختيار التخصص



شرح واضح، أمثلة واقعية، أدوات أساسية، مشاريع تدريبية، وخطة دراسة منظمة لمدة 6 أشهر.

منهج تأسيسي مستقل
مناسب للطلاب والمبتدئين

LEARN · PRACTICE · EXPLAIN

ابدأ من هنا / WELCOME

قبل الأدوات، افهم الأساس

هذا الدليل مصمم ليبني عندك طريقة تفكير تقنية، لا قائمة أوامر للحفظ. ستتدرج من مكونات الكمبيوتر إلى الشبكات والأنظمة والويب، ثم مبادئ الأمن والتحليل والدفاع، وبعدها تختار المسار الذي يناسبك.

كيف تستخدم هذا الدليل؟

01 · افهم

اقرأ الفكرة الأساسية وحاول شرحها بكلماتك قبل الانتقال.

02 · طبّق

نفّذ تجربة صغيرة في جهازك أو مختبر مصمم للتدريب.

03 · وثّق

اكتب الأوامر والنتائج وما تعنيه، لا مجرد صورة للشاشة.

04 · راجع

استخدم قوائم التحقق والأسئلة في نهاية الدليل لقياس فهمك.

قاعدة الاستخدام الآمن

أي فحص أو اختبار أمني يجب أن يكون على أجهزتك، أو داخل مختبر تدريبي، أو ضمن نطاق تملك إذنًا واضحًا لاختباره. إتاحة موقع على الإنترنت لا تعني السماح بفحصه. لا تختبر حسابات الآخرين، ولا تجمع بيانات خاصة، ولا تشغّل أوامر قد تتسبب في حذف ملفات أو تعطيل أنظمة لا تملكها.

الفكرة الأهم

الأداة لا تصنع الفهم. تعلّم المشكلة أولًا، ثم استخدم الأداة المناسبة لجمع الدليل والتحقق من النتيجة.

لمن صُمم الدليل؟

لطالب يبدأ من الصفر، أو لطالب جامعي يريد ترتيب معرفته، أو لمبتدئ انتقل بين دورات كثيرة دون خارطة واضحة. لا تحتاج إلى خبرة اختراق مسبقة؛ تحتاج إلى الفضول، والصبر، والتطبيق المنتظم.

كمبيوتر · شبكات · Windows وLinux · Python · الويب · مبادئ الأمن · مختبرات عملية

تنويه: الدليل تعليمي وتأسيسي. لا يغني عن توثيق الشركات المصنّعة، أو السياسات المؤسسية، أو التدريب المتخصص عند التعامل مع أنظمة حقيقية.

خارطة الطريق

يمكنك قراءة الفصول بالتتابع، أو الرجوع إلى الفصل المناسب عندما تحتاج إلى مراجعة مفهوم محدد.

01 **طريقة التفكير الأمني**
كيف تتعلم، وما الفرق بين الأساس والأداة

02 **أساسيات الكمبيوتر**
المكونات والبيانات والعمليات

03 **الشبكات: العنونة والربط**
IP وMAC وSubnetting وRouting

04 **الشبكات: البروتوكولات والويب**
DNS وDHCP وTCP/UDP والمنافذ وHTTPS

05 **أنظمة التشغيل**
Windows وLinux والطرفية والسجلات

06 **البرمجة وPython**
أساسيات البرمجة ومشاريع للمبتدئ

07 **الويب وقواعد البيانات**
HTTP وAPI وSQL والجلسات

08 **مبادئ الأمن السيبراني**
CIA والمخاطر والتهديدات والثغرات

09 **الهوية والتشفير**
المصادقة والتفويض والتشفير والتجزئة

10 **الحماية والمراقبة**
التحديثات والنسخ الاحتياطية والسجلات

11 **الاختبار الأمني الأخلاقي**
المراحل والأدوات والنطاق المصرّح

12 **SOC والاستجابة للحوادث**
التنبيهات والتحليل والتعافي

13 **GRC وإدارة المخاطر**
الحوكمة والأطر الأمنية

14 **التخصصات المهنية**
كيف تختار مسارك

15 **مختبرات ومشاريع**
تدريبات عملية قابلة للتوثيق

16 **خطة الدراسة لـ6 أشهر**
ماذا تتعلم كل أسبوع

17 **عادات التعلم والتقييم**
روتين أسبوعي واختبار ذاتي

18 **قاموس ومصادر**
مصطلحات أساسية وروابط للتوسع

كيف تقيس التقدم؟

لا تنتقل لأنك شاهدت الدرس. انتقل عندما تستطيع تفسير المفهوم، وتطبيق مثال بسيط، وشرح النتيجة دون نسخ شرح جاهز.

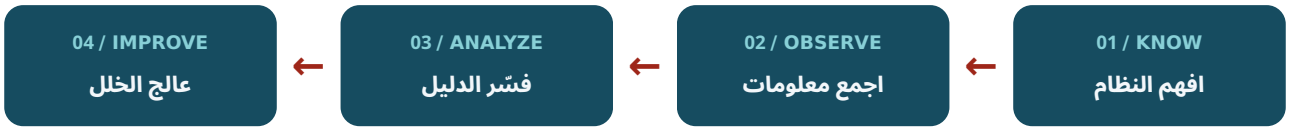
طريقة التفكير الأمني

SECURITY MINDSET

ابدأ ببناء الأساس المشترك، ولا تجعل تعلم الأدوات بديلًا عن فهم الأنظمة. هذا الفصل يشرح كيف تتدرج وما الذي تعنيه المعرفة العملية.

الأمن السيبراني ليس أدوات فقط

تخيّل أنك تريد حماية موقع جامعة. ستحتاج إلى فهم التطبيق وقاعدة البيانات والخادم والشبكة وحسابات المستخدمين والسجلات. الأداة قد تساعد في اختبار جزء من ذلك، لكنها لا تفسر وحدها ما هو طبيعي وما هو خطر.



دورة تعلم وعمل عامة: فهم، ملاحظة، تحليل، ثم تحسين وإعادة تحقق.

طبقات الأساس

الطبقة	ما الذي يجب أن تفهمه؟	مثال على سؤال
الكمبيوتر	الذاكرة والتخزين والعمليات والملفات	ما الفرق بين برنامج وProcess؟
الشبكات	العناوين والتوجيه والبروتوكولات	كيف يصل الجهاز إلى خادم بعيد؟
أنظمة التشغيل	المستخدمون والصلاحيات والخدمات والسجلات	من يشغّل هذه الخدمة وبأي صلاحيات؟
البرمجة	المنطق والشروط والملفات وتحليل البيانات	كيف أكتب سكربتًا يحلل سجلًا؟
الويب	HTTP والجلسات وقواعد البيانات وAPI	أين تُفحص صلاحية الوصول؟
الأمن	المخاطر والضوابط والتحقق والاستجابة	ما الأثر وما الدليل وما المعالجة؟

مصطلحات يجب ألا تخلط بينها

المهارة

قدرتك على تطبيق المفهوم في موقف جديد.

المعرفة

فهم المفهوم ولماذا يعمل بهذه الطريقة.

الدليل

نتيجة قابلة للفحص تدعم استنتاجًا، مع مراعاة حدودها.

الأداة

وسيلة تساعدك على تنفيذ مهمة أو جمع دليل.

أساسيات الكمبيوتر

COMPUTER FUNDAMENTALS

قبل الشبكات والأدوات، افهم الجهاز الذي تعمل عليه: مكوناته، وطبيعة البيانات، وكيف تُشغَّل البرامج وتُدار الصلاحيات.

مكونات الكمبيوتر الأساسية

المكوّن	وظيفته العامة	علاقته بالأمن
CPU	تنفيذ التعليمات ومعالجة العمليات.	يساعد فهم العمليات على تفسير سلوك البرامج واستهلاك الموارد.
RAM	ذاكرة عمل تستخدمها البرامج أثناء التشغيل.	مهمة لفهم حالة النظام والعمليات النشطة وبعض التحليلات الجنائية.
SSD / HDD	تخزين الملفات والبرامج والبيانات على المدى الطويل.	يهم النسخ الاحتياطي، وحماية الملفات، وتحليل آثار الاستخدام.
Motherboard	تربط مكونات الجهاز وتتيح التواصل بينها.	جزء من فهم منصة الجهاز ومكوناته.
NIC / Network Adapter	واجهة اتصال سلكية أو لاسلكية بالشبكة.	أساسية لفهم عناوين الشبكة وحركة البيانات.
Firmware / UEFI	برمجيات منخفضة المستوى تهيئ الجهاز وتبدأ عملية الإقلاع.	تحديثها وحمايتها جزء من أمن المنصة.

البيانات: Bit وByte والأنظمة العددية

يتعامل الكمبيوتر مع البيانات على مستوى منخفض باستخدام قيم ثنائية من 0 و1. يتكوّن البايت عادةً من 8 بتات. ويُستخدم النظام الست عشري لتمثيل القيم الثنائية بطريقة أقصر وأسهل للقراءة، خصوصًا في تحليل البيانات والذاكرة وعناوين الشبكة.

المفهوم	المعنى	مثال أو ملاحظة
Bit	قيمة ثنائية واحدة: 0 أو 1.	وحدة أساسية للبيانات.
Byte	8 Bits عادةً.	قد يمثل حرفًا وفق الترميز المستخدم.
Binary	نظام عددي أساسه 2.	يستخدم الرمزين 0 و1.
Hexadecimal	نظام عددي أساسه 16.	القيمة 0x41 تمثل A في ASCII.
Encoding	طريقة تمثيل البيانات.	UTF-8 مثال شائع لترميز النص.
Metadata	بيانات تصف بيانات أخرى.	قد تتضمن وقت الإنشاء أو نوع الملف.

Program وProcess وService

Process · عملية

نسخة قيد التنفيذ من برنامج، لها حالة وموارد مخصصة.

Program · برنامج

تعليمات مخزنة يمكن تشغيلها، مثل برنامج المتصفح.

User · مستخدم

هوية تعمل ضمن صلاحيات محددة للوصول إلى موارد النظام.

Service · خدمة

مكوّن يقدم وظيفة في الخلفية، مثل خدمة تسمح باتصالات شبكة.

ما الذي تتدرب عليه؟

- افتح Task Manager، وحدد ثلاث عمليات واكتب اسمها واستهلاكها للذاكرة والمعالج.
- ميّز بين مساحة RAM والمساحة المستخدمة على القرص.
- أنشئ مجلدًا وملفًا نصيًا، وتعرف على المسار الكامل للملف.
- تعلّم الفرق بين المستخدم العادي والحساب الإداري.
- لا تحذف عملية أو خدمة لمجرد أنك لا تعرف اسمها؛ ابحث عنها أولًا من مصدر موثوق.

معيار الإتقان

يجب أن تستطيع شرح كيف ينتقل البرنامج من ملف مخزّن إلى عملية تعمل، وما الموارد التي يستخدمها أثناء التنفيذ.

الشبكات: العنونة والربط

NETWORKING I

الشبكات هي أحد أهم الأساسات المشتركة لمعظم تخصصات الأمن السيبراني. الهدف هنا أن تفهم كيف تُعنون الأجهزة وكيف تنتقل البيانات بين الشبكات.

ما هي الشبكة؟

الشبكة مجموعة أجهزة وواجهات مترابطة تتبادل البيانات باستخدام بروتوكولات وقواعد محددة. قد تكون الشبكة محلية في المنزل أو الجامعة، وقد تتصل بشبكات أخرى عبر الإنترنت.

المصطلح	المعنى العملي
LAN	شبكة محلية ضمن مساحة محدودة غالبًا.
WAN	شبكة واسعة تربط مواقع أو شبكات متباعدة.
WLAN	شبكة محلية لاسلكية.
Router	يوجّه حزم البيانات بين شبكات مختلفة.
Switch	يربط أجهزة ضمن شبكة محلية ويوجّه الإطارات بحسب عناوين MAC.
Access Point	يوفر اتصالًا لاسلكيًا بالشبكة.
Firewall	يطبق قواعد للتحكم في حركة الشبكة.
Client / Server	عميل يطلب خدمة، وخادم يقدم الخدمة.

IP وMAC: عنوانان مختلفان

MAC Address

عنوان يستخدم على مستوى ربط البيانات ضمن تقنية الشبكة.
مثال توضيحي: 00:1A:2B:3C:4D:5E

IP Address

عنونة منطقية تساعد على توجيه البيانات بين الشبكات. مثال IPv4: 192.168.1.10

عنوان MAC ليس هوية ثابتة موثوقة للشخص أو الجهاز في كل الظروف؛ يمكن تغييره أو انتحاله في بعض البيئات، كما تستخدم بعض الأجهزة عناوين عشوائية للخصوصية.

IPv4 والعناوين الخاصة

يستخدم IPv4 عناوين بطول 32 بت. من النطاقات الخاصة الشائعة التي لا تُوجَّه مباشرة عبر الإنترنت العام:

النطاق	الاستخدام العام
10.0.0.0/8	عناوين خاصة.
172.16.0.0/12	عناوين خاصة.
192.168.0.0/16	عناوين خاصة شائعة في الشبكات المنزلية.

أما IPv6 فيستخدم عناوين أطول صُممت لتوسيع فضاء العناوين وتحسين جوانب من بنية الاتصال. يجب أن تتعرف على صيغته، حتى إن كانت معظم تدريباتك الأولية على IPv4.

Subnet Mask وCIDR

قناع الشبكة أو بادئة CIDR يحددان أي جزء من عنوان IP يعبّر عن الشبكة وأي جزء يحدد واجهة داخلها. مثال: 192.168.1.10/24 ينتمي عادةً إلى الشبكة 192.168.1.0/24.

> **افهم بدل الحفظ**
>
> لا تتعامل مع /24 كرقم منفصل. تعلّم كيف تحدد عنوان الشبكة ونطاق العناوين القابل للاستخدام بحسب البادئة، وكيف تتأثر النتيجة بوجود IPv4 أو IPv6.

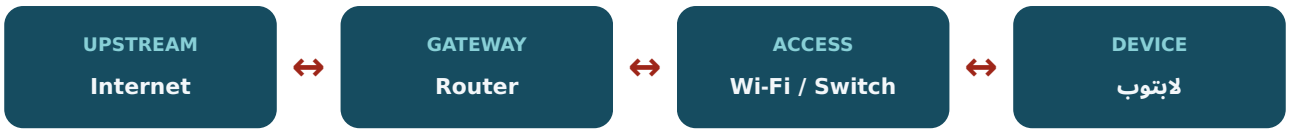
Routing وGateway

إذا أراد جهاز إرسال بيانات إلى وجهة خارج شبكته المحلية، فإنه عادةً يرسلها إلى البوابة الافتراضية المناسبة، ثم تقوم أجهزة التوجيه بتمريرها نحو الشبكة المقصودة. اختيار المسار يعتمد على جداول التوجيه وسياسات الشبكة وحالة المسارات.

Neighbor Discovery وARP

في IPv4، يساعد ARP على اكتشاف عنوان MAC الموافق لعنوان IP على الوصلة المحلية. أما IPv6 فيستخدم Neighbor Discovery ضمن ICMPv6، وليس ARP.

تمرين رسم شبكة



أضف في رسمك: عنوان IP لكل جهاز، والبوابة الافتراضية، ونوع الاتصال، والخدمات التي تحتاج إلى الوصول إليها.

- اعرف عنوان IP الخاص بجهازك وعنوان البوابة الافتراضية.
- ارسم شبكة منزلية من خمسة عناصر على الأقل.
- اشرح لماذا يختلف IP عن MAC.
- حل مسائل بسيطة على IPv4 و/24 ثم توسع تدريجيًا في Subnetting.

الشبكات: البروتوكولات والويب

NETWORKING II

بعد العنونة والتوجيه، تعلّم بروتوكولات النقل والخدمات الأكثر شيوعًا. اربط كل بروتوكول بوظيفته، ثم طبّق ما تستطيع ملاحظته بأمان على جهازك.

بروتوكولات يجب أن تعرف دورها

البروتوكول	الدور العام	ملاحظة أمنية
DNS	تحويل أسماء النطاقات إلى سجلات مثل عناوين IP.	تحليل استعلامات DNS قد يساعد في فهم نشاط الشبكة.
DHCP	توزيع إعدادات الشبكة تلقائيًا.	إعدادات خاطئة قد تسبب اتصالًا غير سليم أو تعرضًا لمخاطر.
TCP	نقل موثوق مع آليات للترتيب وإعادة الإرسال.	يستخدم في اتصالات كثيرة مثل HTTPS فوق HTTP/1.1 أو HTTP/2.
UDP	نقل بسيط لا يوفر وحده ضمانات التسليم والترتيب مثل TCP.	تستخدمه تطبيقات متعددة؛ لا يعني تلقائيًا أن الاتصال غير آمن.
HTTP	طلبات واستجابات الويب.	يجب فهم الطلبات والرؤوس والرموز والجلسات.
TLS	حماية الاتصال بالتشفير والتحقق وفق الإعدادات.	HTTPS يستخدم HTTP فوق اتصال محمي عادةً بـ TLS.
SSH	إدارة واتصال عن بعد بصورة آمنة عند ضبطه جيدًا.	احمِ الحسابات والمفاتيح والصلاحيات.
ICMP	رسائل تحكم وتشخيص للشبكة.	يستخدمه Ping وغيره، وقد تمنع الشبكات بعض الرسائل.

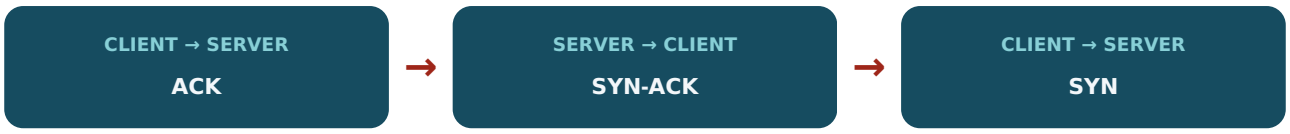
المنافذ: أين تستمع الخدمات؟

رقم المنفذ يساعد نظام التشغيل على توجيه بيانات النقل إلى الخدمة أو التطبيق المقصود. يمكن للخادم نفسه تشغيل خدمات متعددة، ويمكن ضبط الخدمات على منافذ غير افتراضية.

المنفذ الشائع	الخدمة	ما الذي يجب تذكره؟
TCP 22	SSH	إدارة عن بُعد.
TCP 25	SMTP	إرسال البريد بين خوادم وفق الإعداد.
TCP/UDP 53	DNS	نقل استعلامات DNS بحسب السياق.
TCP 80	HTTP	ويب غير مشفر على مستوى النقل.
TCP 443	HTTPS	ويب محمي عادةً عبر TLS.
TCP 445	SMB	مشاركة ملفات وخدمات في بيئات Windows وغيرها.

المنفذ الشائع	الخدمة	ما الذي يجب تذكره؟
TCP 3389	RDP	وصول مكتبي بعيد في Windows.
TCP 3306	MySQL	المنفذ الافتراضي الشائع لقاعدة بيانات MySQL.
TCP 5432	PostgreSQL	المنفذ الافتراضي الشائع لـ PostgreSQL.

TCP Three-Way Handshake



هذه الخطوات تنشئ اتصال TCP. ليست هي نفسها مصادقة المستخدم، ولا تعني أن التطبيق آمن تلقائيًا.

OSI Model في لمحة

7 · Application	خدمات التطبيقات مثل HTTP وDNS
6 · Presentation	تمثيل البيانات وتحويل صيغها في النموذج
5 · Session	تنظيم الجلسات ضمن النموذج المرجعي
4 · Transport	TCP وUDP والمنافذ
3 · Network	IP والتوجيه
2 · Data Link	Ethernet وMAC والإطارات
1 · Physical	الإشارات والوسط الفيزيائي

OSI نموذج مرجعي للتعلم والتحليل؛ لا يمثل تنفيذًا حرفيًا لكل بروتوكول حديث. ادرس أيضًا نموذج TCP/IP.

ماذا يحدث عند فتح موقع؟

1. يقرأ المتصفح اسم النطاق والمسار المطلوب.
2. يستخدم نتيجة DNS محفوظة أو يستعلم عن السجلات اللازمة.
3. يحدد الجهاز كيفية الوصول إلى عنوان الوجهة، مباشرة أو عبر البوابة الافتراضية.
4. ينشئ الاتصال المناسب؛ مع TCP في حالات كثيرة، أو عبر QUIC عند استخدام HTTP/3.
5. عند HTTPS، يجرى إعداد TLS والتحقق من هوية الخادم وفق إعدادات العميل.
6. يرسل المتصفح طلب HTTP ويتلقى استجابة، ثم قد يطلب ملفات وصورًا وبيانات إضافية.

تدريب عملي

استخدم أدوات الشبكة وWireshark على جهازك. راقب أسماء النطاقات والبروتوكولات وعناوين المصدر والوجهة. عند HTTPS لا تتوقع أن ترى محتوى التطبيق نصًا صريحًا؛ التشفير يغيّر ما يمكن ملاحظته.

أنظمة التشغيل: Windows وLinux

OPERATING SYSTEMS

الأنظمة هي البيئة التي تعمل داخلها البرامج والخدمات. فهم المستخدمين والصلاحيات والعمليات والسجلات يساعدك في الدفاع والتحليل والاختبار.

ما الذي تحتاج إلى معرفته عن Windows؟

لا يلزم أن تصبح مسؤول أنظمة محترفًا قبل دخول الأمن السيبراني، لكن يجب أن تعرف كيف تتحرك داخل النظام وتفهم المستخدمين والصلاحيات والعمليات والخدمات والسجلات.

الأداة / المفهوم	ماذا تتعلم؟
Task Manager	العمليات واستهلاك CPU وRAM.
Services	الخدمات العاملة ونوع تشغيلها.
Event Viewer	البحث في سجلات النظام والتطبيقات والأمان.
Windows Firewall	فهم قواعد حركة الشبكة المسموح بها أو الممنوعة.
Windows Defender	فهم الحماية المدمجة وحالة بعض وسائل الدفاع.
PowerShell	استعراض العمليات والخدمات والملفات وأتمتة المهام.
NTFS Permissions	فهم من يستطيع قراءة أو تعديل ملف أو مجلد.

أوامر PowerShell مفيدة كبداية

```
Get-Process
Get-Service
Get-ChildItem
Get-Content .\sample.txt
Get-LocalUser
Get-NetTCPConnection
```

اقرأ ناتج كل أمر وافهمه. قد تختلف النتائج والصلاحيات المتاحة باختلاف إصدار Windows وإعداداته.

ما الذي تحتاج إلى معرفته عن Linux؟

Linux مهم للخوادم والشبكات وكثير من أدوات الأمن. ابدأ بتوزيعة مستخدمية مثل Ubuntu، ثم تعلّم إدارة النظام من الطرفية.

المسار	معناه العام
/	جذر نظام الملفات.

المسار	معناه العام
/home	مجلدات المستخدمين.
/etc	ملفات إعدادات كثيرة للنظام والخدمات.
/var/log	موقع شائع لسجلات النظام والخدمات.
/tmp	ملفات مؤقتة في كثير من الأنظمة.
/proc	واجهة افتراضية لمعلومات العمليات والنظام.

أوامر Linux الأساسية

```
pwd        # اعرف المسار الحالي
ls -la     # اعرض الملفات والتفاصيل
cd folder  # انتقل إلى مجلد
mkdir lab  # أنشئ مجلدًا
cat file.txt
less /var/log/example.log
grep "ERROR" sample.log
find . -name "*.txt"
ps aux
ip a
ss -tulpen
systemctl status ssh
journalctl -n 50
```

المستخدمون والصلاحيات

تعلم الفرق بين المستخدم والمجموعة والمالك، وصلاحيات القراءة والكتابة والتنفيذ، ومفهوم المستخدم الجذر root، ودور sudo. لا تستخدم صلاحيات مرتفعة إلا عند الحاجة، وافهم أثر الأمر قبل تنفيذه.

المبدأ الأمني

أقل صلاحية ممكنة تعني أن الحساب أو الخدمة يحصل على ما يلزم لأداء العمل فقط. إذا كان البرنامج يستطيع العمل دون صلاحيات إدارية، فلا تمنحه صلاحيات أوسع دون سبب واضح.

التطبيق العملي

- أنشئ جهاز Linux افتراضيًا واحفظ لقطة نظيفة قبل التجارب.
- أنشئ مستخدمًا ومجلدًا وملفًا تجريبيًا، ثم افحص الصلاحيات.
- اعرض العمليات والخدمات والمنافذ التي تستمع للاتصالات.
- اقرأ سجلًا تجريبيًا وحدد أحداثًا طبيعية وأحداثًا تحتاج إلى تفسير.
- على Windows، اعثر على سجل أحداث محدد واشرح ما يخبرك به.

البرمجة وPython

PROGRAMMING & PYTHON

البرمجة ليست شرطًا لإتقان كل تخصص، لكنها مهارة تأسيسية قوية. ابدأ بالمنطق والبيانات والملفات، ثم نفّذ مشاريع صغيرة ذات نتائج قابلة للفحص.

هل يجب أن تكون مبرمجًا محترفًا؟

لا يشترط أن تصبح مطورًا محترفًا حتى تبدأ، لكن من المهم أن تفهم المنطق البرمجي وأن تستطيع كتابة سكربتات صغيرة. البرمجة تساعدك على تحليل البيانات، وأتمتة المهام، وفهم سلوك التطبيقات.

لماذا Python؟

Python مناسبة كبداية لأن بنيتها مقروءة، ويمكن استخدامها في تحليل النصوص والملفات والسجلات، والتعامل مع JSON وواجهات API، وبناء أدوات مساعدة بسيطة.

الموضوعات بالترتيب

المستوى	الموضوعات
1. الأساس	Variables، Data Types، Strings، Numbers، Boolean، Operators.
2. المنطق	Conditions، Loops، Lists، Dictionaries، Functions.
3. تنظيم الكود	Modules، Imports، Exceptions، تقسيم البرنامج إلى دوال.
4. الملفات والبيانات	قراءة وكتابة الملفات، JSON، CSV، البحث في النصوص.
5. تطبيقات صغيرة	تحليل سجلات، التحقق من بيانات، طلبات HTTP، تجزئة ملفات.

مثال بسيط: تصنيف محاولات الدخول

```
attempts = 4

if attempts >= 3:
    print("Review the login attempts")
else:
    print("Continue monitoring")
```

البرنامج يطبع رسالة بناءً على عدد محاولات افتراضي. في نظام حقيقي، لا يكفي هذا الشرط وحده لإثبات هجوم؛ يجب دراسة السياق والأدلة الأخرى.

ثلاثة مشاريع تأسيسية

Log Analyzer · 01

اقرأ ملفًا تجريبيًا، واحسب عدد مرات ظهور ERROR وWARNING وFAILED، ثم اطبع ملخصًا.

Login Summary · 02

حلل سجلات تدريبية واحسب محاولات الدخول الفاشلة لكل مستخدم مع عرض الوقت والمصدر إن توفر.

File Hash Checker · 03

احسب SHA-256 لملف، واحتفظ بالقيمة، ثم قارنها بعد تعديل نسخة تدريبية من الملف.

JSON Reader · 04

اقرأ ملف JSON واعرض حقولًا محددة، وتحقق من وجود الحقول وتعامل مع البيانات غير المتوقعة.

متى تتعلم لغات أخرى؟

بعد أن ترتاح مع Python، تعلّم أساسيات Bash أو PowerShell بحسب نظام التشغيل الذي تستخدمه. وإذا اتجهت إلى أمن تطبيقات الويب، فستحتاج إلى فهم JavaScript وSQL بصورة أفضل. وقد تصبح C مهمة لاحقًا لتحليل البرمجيات منخفضة المستوى، لكنها ليست شرط البداية.

تحدي هذا الفصل

اكتب برنامجًا يقرأ سجلًا نصيًا تدريبيًا، ويحصي الأخطاء ومحاولات الدخول الفاشلة، ثم يخرج تقريرًا واضحًا. اشرح كل جزء من الكود دون النظر إلى شرح جاهز.

الويب وقواعد البيانات

WEB & DATABASE FUNDAMENTALS

حتى تختبر تطبيقًا أو تحميه، افهم كيف تنتقل البيانات، وكيف تُدار الجلسات، وما الدور الذي تؤديه قاعدة البيانات وواجهات API.

كيف يعمل تطبيق الويب؟

في نموذج العميل والخادم، يرسل المتصفح أو التطبيق طلبًا إلى خادم، ويعالج الخادم الطلب ويعيد استجابة. قد تتضمن الاستجابة HTML أو JSON أو ملفات أخرى. وقد يستعين الخادم بقاعدة بيانات أو خدمات داخلية.

المكوّن	وظيفته العامة
HTML	يبني بنية المحتوى والعناصر.
CSS	ينسق مظهر الصفحة.
JavaScript	ينفذ منطقًا في المتصفح، ويمكن استخدامه في بيئات أخرى.
HTTP	بروتوكول الطلبات والاستجابات بين العميل والخادم.
API	واجهة تسمح للبرامج بتبادل البيانات والوظائف.
Database	تخزن بيانات منظمة يحتاج إليها التطبيق.

مكونات طلب HTTP

من المهم أن تتعرف على Method وPath وHeaders وBody عند وجوده، وأن تفهم كيف يستجيب الخادم وكيف يتعامل التطبيق مع الأخطاء.

Method / Status	الاستخدام أو المعنى العام
GET	طلب بيانات.
POST	إرسال بيانات أو طلب تنفيذ عملية.
PUT / PATCH	إنشاء أو استبدال مورد، أو تعديل جزء منه بحسب تصميم API.
DELETE	طلب حذف مورد.
200	نجاح في حالات شائعة.
301 / 302	تحويل دائم أو مؤقت في حالات شائعة.
400	الطلب غير صالح.

Method / Status	الاستخدام أو المعنى العام
401	غالبًا يلزم تحقق من المصادقة أو أن المصادقة غير مقبولة.
403	رفض الوصول.
404	المورد غير موجود أو غير مكشوف.
500	خطأ داخلي في الخادم.

طرق HTTP ورموز الاستجابة لا تكشف وحدها كل قواعد العمل؛ فالسلوك الفعلي يعتمد على تصميم التطبيق وإعداده.

Cookie وSession

Cookie بيانات صغيرة يخزنها المتصفح، وقد تحمل معرّف جلسة أو تفضيلات. أما Session فهي آلية للحفاظ على حالة المستخدم بين عدة طلبات. عند تسجيل الدخول، قد يربط الخادم الجلسة بمعرّف محفوظ داخل Cookie. حماية الجلسة، وإبطالها عند الخروج، وضبط خصائص Cookie أمور أمنية مهمة.

قواعد البيانات وSQL

تعلم Table وRow وColumn وPrimary Key وForeign Key، ثم أساسيات SELECT, INSERT, UPDATE, DELETE, WHERE, JOIN. أمان قاعدة البيانات لا يعتمد فقط على كلمات المرور؛ يجب أيضًا التحقق من المدخلات، وتقييد الصلاحيات، واستخدام الاستعلامات المعلّمة أو المجهزة لتقليل مخاطر الحقن.

المصادقة مقابل التفويض في تطبيق ويب

مثال عملي

قد ينجح المستخدم في تسجيل الدخول (Authentication)، لكنه لا يملك حق تعديل سجل طالب آخر (Authorization). يجب أن يتحقق الخادم من صلاحية كل عملية حساسة، لا أن يعتمد على إخفاء زر في المتصفح فقط.

تجربة آمنة في المتصفح

- افتح Developer Tools في متصفحك، وانتقل إلى Network.
- راقب طلبًا عامًا في موقع تملكه أو تطبيقًا تجريبيًا.
- لاحظ Method وStatus Code وHeaders ونوع المحتوى.
- افحص طلب JSON في API تدريبي، واكتب ما الذي يرسله العميل وما الذي يعيده الخادم.
- لا تغيّر معرّفات أو صلاحيات أو بيانات مستخدمين في أنظمة حقيقية دون إذن محدد.

مبادئ الأمن السيبراني

CYBERSECURITY PRINCIPLES

هذا الفصل هو قلب التفكير الأمني: ما الذي نحميه، وما الذي قد يهدده، وكيف نميز الضعف عن التهديد والمخاطرة، وكيف نختار ضوابط مناسبة.

ما هو الأمن السيبراني؟

هو مجموعة من الممارسات والعمليات والتقنيات لحماية الأنظمة والشبكات والتطبيقات والبيانات، وإدارة المخاطر المرتبطة بها. لا توجد أداة واحدة تمنح حماية كاملة؛ الحماية دورة مستمرة تشمل الوقاية والاكتشاف والاستجابة والتعافي.

مثلث CIA

Integrity · سلامة البيانات

منع التغيير غير المصرح أو غير الصحيح. مثال: منع تعديل درجات الطلاب دون تصريح.

Confidentiality · السرية

لا يطّلع على المعلومات إلا من لديه صلاحية مناسبة. مثال: حماية رواتب الموظفين من الوصول غير المصرح.

Availability · التوافر

بقاء الخدمة متاحة عند الحاجة. مثال: تقليل توقف بوابة الجامعة وتعزيز القدرة على التعافي.

Asset وThreat وVulnerability وExploit وRisk

المفهوم	الشرح	مثال في مؤسسة تعليمية
Asset · أصل	شيء له قيمة ويجب حمايته.	قاعدة بيانات الطلاب.
Threat · تهديد	عامل أو حدث يمكن أن يسبب ضررًا.	شخص يحاول الوصول إلى السجلات دون تصريح.
Vulnerability · ضعف	خلل في التقنية أو الإعداد أو العملية.	التطبيق لا يتحقق من صلاحية الوصول لكل سجل.
Exploit · استغلال	طريقة تستخدم للاستفادة من ضعف.	طلب غير مصرح يكشف سجل طالب آخر في مختبر تجريبي.
Risk · مخاطرة	احتمال وتأثير حدث ضار ضمن سياق معين.	احتمال كشف بيانات حساسة وما يترتب عليه من أثر.

ما هو Attack Surface؟

سطح الهجوم هو مجموعة الواجهات والنقاط التي قد يحاول شخص التفاعل معها للوصول إلى النظام أو إساءة استخدامه. قد يشمل خدمات الشبكة، وتطبيقات الويب، وواجهات API، وحسابات المستخدمين، والأجهزة، والخدمات السحابية، ومكونات الطرف الثالث.

كيف نفكر بالمخاطر؟

ابدأ بتحديد الأصل، ثم التهديد والضعف المحتملين، ثم تقدير احتمال الحادثة وأثرها في ظل الضوابط الحالية. هذا تقدير تحليلي وليس دائمًا معادلة رياضية دقيقة. قد يكون الضعف شديدًا من الناحية التقنية، لكن أولويته الفعلية تتأثر بالسياق والأثر وإمكانية الاستغلال.

مثال متكامل

إذا لم يتحقق التطبيق من صلاحية المستخدم على كل سجل، فقد يستطيع مستخدم الوصول إلى بيانات لا يحق له رؤيتها. المعالجة لا تقتصر على إخفاء الصفحة؛ بل تتطلب إصلاح التحقق على الخادم، واختبار الإصلاح، ومراجعة السجلات وتقدير الأثر.

Defense in Depth

الدفاع متعدد الطبقات يعني عدم الاعتماد على إجراء واحد. قد تجمع المؤسسة بين المصادقة متعددة العوامل، والصلاحيات المحدودة، والتحديثات، والجدار الناري، والتسجيل والمراقبة، والنسخ الاحتياطية، وخطة الاستجابة للحوادث. الهدف أن تقل احتمالية الحادث وأن يُحد الأثر إذا فشلت إحدى وسائل الحماية.

Threat Modeling

نمذجة التهديدات هي طريقة منظمة لطرح الأسئلة الأمنية قبل بناء النظام أو أثناء تطويره: ما الأصول؟ من يستخدم النظام؟ أين تنتقل البيانات؟ ما الذي قد يُساء استخدامه؟ وما الضوابط التي تقلل المخاطر؟

- لا تعتبر وجود ثغرة دليلًا تلقائيًا على أن استغلالها سهل أو ممكن في كل الظروف.
- لا تعتبر وجود تنبيه دليلًا تلقائيًا على وقوع هجوم.
- لا تعتبر وجود تشفير دليلًا على أن النظام آمن بالكامل.
- اربط كل مشكلة بالأصل والأثر والدليل والمعالجة.

الهوية والتشفير

IDENTITY & CRYPTOGRAPHY

افهم من يدخل النظام، وما الصلاحيات التي يحصل عليها، وكيف تُحمى البيانات أثناء التخزين والنقل. ميّز بين مفاهيم تبدو متشابهة لكنها تؤدي وظائف مختلفة.

Authentication وAuthorization

Authorization · التفويض

تحديد ما الذي يسمح للهوية بفعله بعد المصادقة. مثال: السماح لموظف بقراءة تقارير قسمه دون تعديل إعدادات الإدارة.

Authentication · المصادقة

التحقق من هوية المستخدم أو الجهاز. مثال: إثبات الهوية أثناء تسجيل الدخول.

نجاح تسجيل الدخول لا يعني أن المستخدم يمتلك صلاحية لكل مورد. يجب تطبيق التحقق من الصلاحيات في المكان المناسب، خصوصًا على الخادم والبيانات الحساسة.

مبادئ إدارة الوصول

المبدأ	لماذا يهم؟
MFA	تضيف عامل تحقق آخر، فتقلل الاعتماد على كلمة المرور وحدها.
Least Privilege	تمنح المستخدم أو الخدمة الصلاحيات الضرورية فقط.
RBAC	تربط الصلاحيات بأدوار معرفة داخل المؤسسة.
Account Lifecycle	تضمن إنشاء الحسابات وتعديلها وتعطيلها عند تغير الحاجة.
Privileged Access	تتطلب عناية إضافية بالحسابات ذات الامتيازات العالية.

التشفير والتجزئة والترميز

المفهوم	وظيفته	مثال / تنبيه
Encryption · التشفير	حماية سرية البيانات باستخدام خوارزمية ومفتاح.	AES مثال على تشفير متماثل.
Asymmetric Cryptography	استخدام زوج مفاتيح عام وخاص في وظائف تشفيرية مناسبة.	RSA مثال معروف؛ تختلف الوظيفة بحسب الاستخدام.
Hashing · التجزئة	إنتاج قيمة ثابتة الطول من البيانات.	SHA-256؛ ليس تشفيرًا قابلًا للفك.
Encoding · الترميز	تمثيل البيانات بصيغة محددة.	Base64 لا يوفر السرية وحده.

المفهوم	وظيفته	مثال / تنبيه
Digital Signature	التحقق من سلامة البيانات وربطها بمفتاح توقيع.	الثقة في هوية المصدر تعتمد أيضًا على التحقق من المفتاح.
Password Hashing	تخزين تمثيل مشتق يصعّب استرجاع كلمة المرور.	Argon2id أو bcrypt أو scrypt مع Salt وإعدادات مناسبة.

ما دور TLS والشهادات؟

عند استخدام HTTPS، يمكن أن يحمي TLS الاتصال بين العميل والخادم ويوفر آليات للتحقق من هوية الخادم وفق نظام الشهادات وإعدادات التحقق. الشهادة تربط مفتاحًا عامًا بهوية ضمن سياق معين، وتساعد جهة موثوقة أو سلسلة ثقة على التحقق منها. وجود HTTPS لا يضمن أن التطبيق نفسه خالٍ من الثغرات.

مصطلحات إضافية

- Salt: قيمة عشوائية فريدة عادةً تضاف قبل تجزئة كلمة المرور، وتخزن معها وفق تصميم آمن.
- Certificate Authority (CA): جهة تصدر الشهادات وفق سياسات تحقق محددة.
- Key Management: إنشاء المفاتيح وحفظها وتدويرها وإبطالها والتخلص منها عند الحاجة.
- Zero Trust: لا تمنح الثقة أو الصلاحيات الواسعة لمجرد أن المستخدم داخل الشبكة؛ تحقق وفق الهوية والسياق والجهاز والسياسات.

تجربة آمنة

احسب SHA-256 لملف صغير، ثم غيّر نسخة تدريبية منه وأعد الحساب. ستلاحظ اختلاف قيمة التجزئة. تذكّر أن تطابق Hash لا يثبت وحده أصالة الملف أو هوية ناشره؛ يلزم سياق موثوق للتحقق من المصدر.

الحماية والمراقبة

DEFENSE & MONITORING

في الأنظمة الواقعية، الأمن يعتمد على إجراءات مستمرة: تحديثات، وضبط صلاحيات، ونسخ احتياطي، وسجلات، ومراقبة، واستجابة منظمة عند ظهور مشكلة.

الضوابط الأمنية الأساسية

Backup & Recovery

نسخ احتياطي محمي واختبار استعادة حقيقي، لا مجرد وجود ملفات منسوخة.

Patch Management

إدارة التحديثات الأمنية بعد تقييمها وتطبيقها والتحقق من نجاحها.

Endpoint Protection

وسائل حماية ومراقبة على أجهزة المستخدمين والخوادم.

Firewall

قواعد تتحكم في حركة الشبكة بحسب المصدر والوجهة والمنفذ والسياق.

كيف تتم إدارة الثغرات؟

1. تحديد الأصول والأنظمة ضمن النطاق.
2. فحص الأنظمة بحثًا عن نقاط ضعف محتملة بأدوات وإجراءات مناسبة.
3. التحقق من النتائج لتقليل الإنذارات غير الصحيحة.
4. تقدير الأولوية بحسب الخطورة والأثر والتعرض والسياق.
5. معالجة الثغرة أو تطبيق تدابير تخفيف مؤقتة عند تعذر الإصلاح الفوري.
6. إعادة الاختبار للتحقق من نجاح المعالجة وتوثيق النتيجة.

Monitoring وLogging

تسجل الأنظمة أحداثًا وفق قدراتها وإعداداتها، مثل محاولات الدخول وتغيير الإعدادات وأخطاء التطبيقات وتشغيل الخدمات واتصالات الشبكة. تساعد السجلات على فهم ما حدث، لكنها قد تكون ناقصة أو غير متاحة إذا لم تُفعّل الإعدادات المناسبة أو لم تُحفظ بصورة سليمة.

IDS وIPS وEDR وSIEM

التقنية	الدور العام
IDS	اكتشاف حركة أو سلوك شبكي قد يكون مشبوهًا.
IPS	اكتشاف أنشطة محددة ومنع بعضها بحسب السياسات والإعدادات.

التقنية	الدور العام
EDR	مراقبة نشاط نقاط النهاية ودعم اكتشاف السلوك المشبوه والتحقيق والاستجابة.
SIEM	تجميع أحداث أمنية من مصادر متعددة وربطها وإنتاج تنبيهات وتقارير.
Antivirus	اكتشاف بعض البرمجيات الخبيثة والتعامل معها.
VPN	إنشاء اتصال شبكي افتراضي، وغالبًا قناة محمية بحسب التقنية والإعداد.

هذه التقنيات ليست بدائل متطابقة. وقد تنتج تنبيهات كاذبة أو تفوت نشاطًا حقيقيًا؛ لذلك تحتاج إلى إعداد مناسب وتحقيق بشري وسياق كافٍ.

النسخ الاحتياطي ليس مزامنة

المزامنة تنقل التغييرات بين مواقع أو أجهزة، لكنها قد تنقل الحذف أو التشفير الخبيث أيضًا. النسخة الاحتياطية ينبغي أن تكون محمية بشكل مناسب، وأن تُختبر إمكانية استعادتها، وأن تُصمم بحسب احتياجات المؤسسة ومدى تحملها لفقد البيانات أو توقف الخدمة.

مبدأ مهم

التحديث والنسخ الاحتياطي والتسجيل والمراقبة ليست مهامًا منفصلة عن الأمن؛ إنها جزء من دورة تقليل المخاطر، واكتشاف المشكلة، والتعافي بعد الحادثة.

الاختبار الأمني الأخلاقي

ETHICAL SECURITY TESTING

اختبار الاختراق نشاط مهني يتطلب إذنًا ونطاقًا واضحًا وفهمًا للنظام. تعلّم منهجيته قبل استخدام الأدوات وتجنب إحداث أثر غير ضروري.

ما هو الاختبار الأمني الأخلاقي؟

هو فحص منظم ومصرّح به لاكتشاف نقاط ضعف وتوثيق أثرها ومساعدة مالك النظام على إصلاحها. ليس مجرد تشغيل أداة على أي عنوان تراه على الإنترنت.

قبل أن تبدأ

- تأكد من وجود إذن واضح ونطاق مكتوب يحدد الأنظمة والأنشطة المسموحة.
- افهم القيود: ما الذي لا يجوز فحصه؟ وهل توجد أنظمة إنتاجية حساسة؟
- حدد قواعد التوقف والتواصل عند ظهور مشكلة أو أثر غير متوقع.
- لا تجمع بيانات حقيقية أكثر مما يلزم، ولا تغير أو تحذف بيانات لا تحتاج إليها.
- احفظ الأدلة بطريقة آمنة ووثق الوقت والأوامر والنتائج.

مراحل اختبار عامة

1. تحديد النطاق والأهداف وقواعد العمل.
2. جمع المعلومات المسموح بها عن النظام.
3. استكشاف الخدمات والإعدادات ونقاط الضعف المحتملة.
4. التحقق من النتائج لتحديد ما إذا كانت المشكلة حقيقية.
5. تقدير الأثر ضمن حدود الاختبار المسموح بها.
6. كتابة تقرير واضح يحتوي على الأدلة والمخاطر والمعالجة المقترحة.
7. إعادة الاختبار للتحقق من أن الإصلاح نجح.

أدوات تبدأ بها، بعد فهم الأساس

الأداة	الاستخدام	المعرفة السابقة المطلوبة
Wireshark	التقاط حركة الشبكة وتحليل البروتوكولات.	TCP/IP وDNS وHTTP.
Nmap	استكشاف الشبكات والخدمات في نطاق مصرح به.	IP والمنافذ والخدمات.
Burp Suite	فحص طلبات الويب والاستجابات ضمن مختبر آمن.	HTTP والجلسات والمصادقة.
Kali Linux	بيئة Linux تتضمن أدوات اختبار متعددة.	Linux والشبكات ومبادئ الاختبار.
VirtualBox	إنشاء أجهزة افتراضية لمختبرات معزولة.	نظام التشغيل وإعدادات الشبكة الأساسية.

الأداة	الاستخدام	المعرفة السابقة المطلوبة
Git	تتبع تغييرات الشيفرة وتنظيم المشاريع.	أساسيات الطرفية والملفات.

كيف تبدأ اختبار الويب بأمان؟

ابدأ بمختبرات مصممة للتعلم، وافهم سبب الثغرة وطريقة منعها. لا تختبر تطبيقات حقيقية دون إذن. لا تستخدم أي مخرجات فحص لتبرير الوصول إلى بيانات خاصة أو تجاوز صلاحيات الآخرين.

لا تقفز إلى Kali

Kali أداة وبيئة عمل، وليست بديلًا عن فهم أنظمة التشغيل والشبكات. إذا لم تفهم لماذا ظهر منفذ مفتوح، فتعلم الخدمة والبروتوكول قبل الانتقال إلى خطوات الاختبار التالية.

شكل تقرير جيد

- ملخص تنفيذي بلغة مفهومة.
- النطاق والحدود والمنهجية.
- وصف واضح لكل نتيجة مدعومة بالدليل.
- الأثر المحتمل مع توضيح الافتراضات والقيود.
- خطوات معالجة عملية وقابلة للتحقق.
- إعادة الاختبار وتاريخ التحقق من الإصلاح.

SOC والاستجابة للحوادث

SOC, INCIDENT RESPONSE & FORENSICS

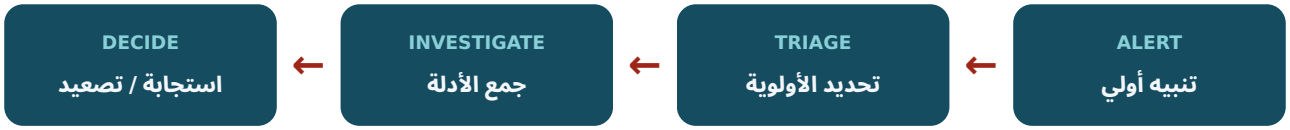
الدفاع يتطلب ملاحظة الأحداث، وطرح أسئلة صحيحة، وربط الأدلة، وتوثيق الاستنتاجات، ثم اتخاذ إجراء مناسب بحسب السياسات.

ما هو SOC؟

Security Operations Center هو فريق أو وظيفة مسؤولة عن مراقبة الأحداث الأمنية وتحليل التنبيهات والتنسيق في الاستجابة للحوادث. تختلف صلاحيات الفريق وإجراءاته بحسب المؤسسة وحجمها وأدواتها.

كيف يفكر محلل الأمن؟

عند ظهور تنبيه عن محاولات دخول فاشلة، لا يقرر المحلل مباشرة أن الحساب مخترق. بل يتحقق من الوقت والمصدر والتكرار والمحاولات الناجحة اللاحقة وسلوك الحساب والتنبيهات المرتبطة، ثم يقرر الخطوة التالية وفق الأدلة والإجراءات المعتمدة.



ما الذي تحلله؟

- سجلات تسجيل الدخول الناجح والفاشل.
- تغييرات الصلاحيات وإعدادات الحسابات.
- أحداث النظام والتطبيقات والخدمات.
- اتصالات الشبكة وطلبات DNS، بحسب ما توفره أدوات التسجيل.
- الوقت والتسلسل والعلاقة بين الأحداث من مصادر مختلفة.

Incident Response · الاستجابة للحوادث

عملية منظمة للتعامل مع الحوادث الأمنية. تشمل عادةً التحضير، والاكتشاف والتحليل، والاحتواء، والمعالجة، والتعافي، والتعلم من الحادث. في حالة واقعية، اتبع إجراءات المؤسسة وخطة الاستجابة، ولا تتخذ إجراءً قد يدمّر الأدلة أو يوسع الضرر.

Digital Forensics · التحليل الجنائي الرقمي

جمع الأدلة الرقمية وفحصها وتفسيرها بطريقة تحافظ على موثوقيتها. قد تشمل الأدلة الملفات وسجلات النظام وحركة الشبكة وآثار تشغيل البرامج أو بيانات الذاكرة. تختلف متطلبات حفظ الأدلة وسلسلة الحيازة بحسب الغرض والسياسات والمتطلبات القانونية.

قاعدة التحليل

افصل بين الحقيقة والاستنتاج. اكتب ما رأيته في السجل أولًا، ثم ما الذي قد يعنيه، ثم ما الأدلة الإضافية التي تحتاجها لتأكيد الفرضية أو رفضها.

شكل ملاحظة جيدة

```
الوقت: 10:42:18
المصدر: سجل نظام تجريبي
الملاحظة: 12 محاولة دخول فاشلة خلال 4 دقائق
الفرضية: نشاط يستحق التحقق
ما ينقص: نتيجة المحاولات اللاحقة، هوية المصدر، وسياق المستخدم
الخطوة التالية: مراجعة السجلات المرتبطة وفق إجراء المؤسسة
```

GRC وإدارة المخاطر

GOVERNANCE, RISK & COMPLIANCE

الأمن لا يعتمد على التقنية وحدها. الحوكمة وإدارة المخاطر والامتثال تساعد على توجيه الجهد، وتحديد المسؤوليات، وإثبات أن الضوابط مطبقة بفاعلية.

ما هو GRC؟

Risk Management · إدارة المخاطر

تحديد المخاطر وتحليلها واختيار كيفية التعامل معها.

Governance · الحوكمة

تحديد المسؤوليات والسياسات وآلية اتخاذ القرار والمتابعة.

Compliance · الامتثال

الالتزام بالقوانين والمتطلبات التنظيمية والمعايير والسياسات المناسبة.

عمل GRC ليس أقل تقنية من غيره؛ بل يربط الاحتياجات التشغيلية والمخاطر والضوابط والأدلة بالمسؤوليات والقرارات. وقد تتضمن المهام تقييم المخاطر، ومراجعة السياسات، وجمع أدلة تطبيق الضوابط، ومتابعة خطط المعالجة.

NIST Cybersecurity Framework 2.0

إطار يساعد المؤسسات على تنظيم جهود إدارة مخاطر الأمن السيبراني. يتضمن ست وظائف مترابطة، وليست مراحل إلزامية يجب إكمال واحدة بالكامل قبل التالية.

الوظيفة	ما الذي تركّز عليه؟
Govern · الحوكمة	الاستراتيجية والمسؤوليات والسياسات والإشراف.
Identify · التحديد	الأصول والسياق والمخاطر والاعتماديات.
Protect · الحماية	تدابير تقلل احتمال وقوع الحوادث وأثرها.
Detect · الاكتشاف	ملاحظة النشاط غير المتوقع أو الحوادث.
Respond · الاستجابة	اتخاذ إجراءات عند وقوع الحادث وتحليل أثره.
Recover · التعافي	استعادة الوظائف وتحسين القدرة على الصمود.

كيف توثق خطرًا بطريقة عملية؟

الحقل	مثال توضيحي
الأصل	حسابات موظفي الجامعة.

الحقل	مثال توضيحي
السيناريو	استخدام حساب موظف دون إذنه.
الضعف المحتمل	غياب MFA أو ضعف عملية استعادة الحساب.
الأثر	وصول غير مصرح إلى بيانات بحسب صلاحيات الحساب.
الضوابط الحالية	كلمة مرور، وسجلات دخول، وسياسة حسابات.
المعالجة المقترحة	تفعيل MFA، تحسين الاستعادة، مراجعة الوصول والتنبيهات.
طريقة التحقق	اختبار إعدادات المصادقة ومراجعة أدلة التسجيل.

في تقييم واقعي، يجب ربط مستوى المخاطر بمنهجية المؤسسة ومعاييرها وسياقها، لا الاكتفاء بوصف عام أو رقم غير مفسر.

لماذا هذا مهم؟

أي مؤسسة تحتاج إلى معرفة ما الذي تحميه، وما المخاطر ذات الأولوية، ومن المسؤول عنها، وما الدليل على أن الضوابط تعمل. هذا هو الجسر بين التقنية والإدارة.

التخصصات المهنية

CAREER PATHS

بعد بناء الأساس، جرّب مسارات مختلفة قبل الالتزام بتخصص واحد. اختر بناءً على نوع المشكلات التي تحب حلها، لا على الاسم أو الانطباع فقط.

الأمن السيبراني مجموعة مسارات متداخلة، وليس وظيفة واحدة. لا تحتاج إلى اختيار مسارك النهائي من أول أسبوع؛ تعلّم أساسًا مشتركًا ثم جرّب مشروعًا صغيرًا في مجال أو مجالين.

المسار	ماذا يفعل صاحبه؟	الأساس الأهم
SOC Analyst	مراقبة التنبيهات وتحليل السجلات وتصعيد الحوادث.	الشبكات، Linux، Windows، السجلات.
Incident Response	التحقيق في الحوادث واحتواؤها والتعافي منها.	الأنظمة، الشبكات، التحليل والتوثيق.
Penetration Testing	اختبار الأنظمة المصرح بها وتوثيق نقاط الضعف.	الشبكات، Linux، الويب، البرمجة.
Web Application Security	تحليل وحماية تطبيقات الويب وواجهات API.	HTTP، JavaScript، SQL، المصادقة والتفويض.
Digital Forensics	فحص الأدلة الرقمية وتفسيرها.	أنظمة التشغيل، الملفات، السجلات.
Malware Analysis	تحليل سلوك البرمجيات الخبيثة وخصائصها.	أنظمة التشغيل، البرمجة، الشبكات.
Cloud Security	حماية الحسابات والخدمات والبيانات السحابية.	IAM، الشبكات، Linux، بنية السحابة.
Application Security	دمج الأمن في التصميم والتطوير والاختبار.	البرمجة، تصميم التطبيقات، الاختبار.
GRC	إدارة المخاطر والسياسات والامتثال والضوابط.	التوثيق، المخاطر، المعايير، التواصل.
Network Security	حماية البنية الشبكية وضبط الوصول والمراقبة.	Routing، Switching، Firewall، protocols.

كيف تختار؟

جرّب

نفذ تمرينًا بسيطًا في الشبكات، وآخر في تحليل السجلات، وآخر في أمن الويب.

لاحظ طريقة تفكيرك

هل تستمتع بالتحقيق في الأدلة؟ أم فهم التطبيقات؟ أم تصميم الضوابط والتوثيق؟

اختر مشروعًا لا لقبًا

المشروع الصغير يعطيك صورة أوضح عن طبيعة العمل من الاسم وحده.

تخصص مع بقاء الأساس

واصل مراجعة الشبكات وأنظمة التشغيل والبرمجة حتى بعد اختيار المسار.

مختبرات ومشاريع قابلة للتوثيق

LABS & PORTFOLIO

> التطبيق يحول النظرية إلى مهارة. أنشئ مختبرًا آمنًا، وابدأ بمشاريع صغيرة، ووثّق خطواتك ونتائجك بدل جمع لقطات شاشة فقط.

بناء مختبر تعلم آمن

لا تحتاج إلى مختبر ضخم. ابدأ بجهازك الأساسي، وجهاز افتراضي Linux، وأدوات الشبكات، ومجلد منظم للملاحظات. أضف Windows افتراضيًا أو تطبيقًا ضعيفًا للتدريب عندما تحتاج إلى ذلك، مع عزل البيئة واتباع إرشادات المنصة.

المكوّن	الغرض	ملاحظة
VirtualBox أو VMware	تشغيل أنظمة افتراضية.	احتفظ بلقطة نظيفة قبل التجارب.
Ubuntu VM	تعلم Linux والخدمات والسجلات.	ابدأ بإعدادات بسيطة.
Wireshark	تحليل حركة من مختبرك.	راقب البيانات التي لديك إذنًا بالتقاطها.
Python	مشاريع تحليل وأتمتة بسيطة.	احفظ الكود مع شرح الاستخدام.
Git	تتبع تغييرات المشاريع.	لا ترفع كلمات مرور أو مفاتيح أو بيانات حساسة.
ملاحظات منظمة	توثيق التعلم والنتائج.	سجل الهدف والخطوات والنتيجة والاستنتاج.

مشروع 1: خريطة شبكة شخصية

1. ارسم أجهزتك وراوترك ونقاط الاتصال.
2. حدد العناوين والخدمات التي تعرفها دون نشر بياناتك الخاصة.
3. اشرح كيف يصل الجهاز إلى بوابته الافتراضية.
4. أضف مخاطر محتملة وضوابط مناسبة مثل تحديث الراوتر وكلمات مرور الإدارة.

مشروع 2: محلل سجلات

1. أنشئ ملف سجلات وهميًا يحتوي على أوقات وأحداث وأسماء مستخدمين تجريبية.
2. اكتب برنامج Python يحصي الأحداث المتكررة ويصنفها.
3. أضف معالجة للأخطاء والتحقق من الحقول.
4. اكتب تقريرًا يوضح ما الذي اكتشفه البرنامج وما الذي لا يمكنه إثباته.

مشروع 3: تقرير أساسيات Linux

1. اعرض العمليات والخدمات والمنافذ المستمعة في جهاز افتراضي تملكه.
2. افحص صلاحيات مجموعة من الملفات التجريبية.

3. راجع سجلًا واحدًا مرتبطًا بخدمة.
4. اكتب توصيتين لتحسين الأمان واشرح سبب كل توصية.

مشروع 4: تحليل طلب HTTP

1. استخدم تطبيقًا محليًا أو مختبرًا تدريبيًا.
2. التقط طلبًا عامًا في Developer Tools.
3. حدد Method وPath وStatus Code وHeaders.
4. اشرح أين يجب أن يتم التحقق من المصادقة والتفويض.

قالب توثيق كل مختبر

```
اسم التجربة:
الهدف:
النطاق والبيئة:
المتطلبات:
الخطوات:
النتائج المرصودة:
التفسير:
القيود والأسئلة المفتوحة:
ما تعلمته:
مصادر الرجوع:
```

المشروع الجيد ليس الأطول

أفضل مشروع تأسيسي هو الذي تستطيع شرحه من البداية إلى النهاية، وتوضح فيه ما فعلته، وما وجدته، وما تعنيه النتيجة، وحدود استنتاجك.

خطة دراسة منظمة لمدة 6 أشهر

SIX-MONTH ROADMAP

> هذه خارطة بداية عملية وليست ضمانًا لإتقان المجال خلال 6 أشهر. الهدف أن تبني أساسًا وتنجز مشاريع بسيطة ثم تختار تخصصًا وتواصل التعمق.

الخطة التالية نموذج مرن لمدة 24 أسبوعًا، بافتراض نحو 8 إلى 10 ساعات أسبوعيًا. إذا كانت لديك خلفية تقنية، قد تتقدم أسرع؛ وإذا كان الموضوع جديدًا تمامًا، كرر الأسابيع الصعبة دون استعجال.

نظرة على الأشهر الستة

الشهر	التركيز	المخرج العملي بنهاية الشهر
1	الكمبيوتر والشبكات	خريطة شبكة وشرح رحلة طلب موقع.
2	Windows وLinux	مختبر Linux مع مستخدمين وصلاحيات وسجلات.
3	Python والويب وقواعد البيانات	برنامج تحليل سجل مع تقرير.
4	المبادئ الأمنية والتشفير	تقييم مخاطر مبسط لمؤسسة افتراضية.
5	الأدوات والتطبيق الأمني	تحليل حركة وسجلات في مختبر مصرح.
6	مشروع وتخصص	مشروع موثق وتقرير يعرض الأدلة والتوصيات.

التوزيع الأسبوعي

الأسبوع	الموضوع	التطبيق المطلوب
1	مكونات الكمبيوتر والبيانات	تفسير CPU/RAM/Storage والعمليات.
2	IP وMAC وGateway	رسم شبكة منزلية.
3	DNS وDHCP وTCP/UDP والمنافذ	استعلامات وتشخيصات أساسية.
4	Subnetting وOSI وWireshark	تحليل اتصال وشرح ما لوحظ.
5	Windows users/processes/services	استكشاف العمليات والخدمات.
6	PowerShell وEvent Viewer	قراءة حدث وكتابة ملاحظة.
7	Linux filesystem/permissions	إنشاء مستخدم وملفات وفهم الصلاحيات.
8	Linux services/logs/network	تقرير مختصر عن حالة النظام.
9	Python variables/conditions/loops	حل تمارين منطقية.

الأسبوع	الموضوع	التطبيق المطلوب
10	Functions/files/JSON/exceptions	محلل نصوص بسيط.
11	HTTP/HTML/JS/Cookies	تحليل طلب من المتصفح.
12	SQL وAPI والمصادقة	مشروع بيانات صغير.
13	CIA وAsset/Threat/Vulnerability/Risk	جدول مخاطر.
14	Authentication/Authorization/IAM	تقييم سيناريو صلاحيات.
15	Hashing/Encryption/TLS	شرح الفروقات وتجربة Hash.
16	Backups/patching/logging	قائمة ضوابط لمختبر.
17	Wireshark والتحليل الشبكي	تفسير حركة تدريبية.
18	Nmap والمنافذ والخدمات	فحص محدود على مختبرك فقط.
19	أساسيات أمن الويب	مختبر تعليمي مصرح وتقرير.
20	تحليل سجلات وتنبيهات	تقرير تحقيقي من بيانات تجريبية.
21	مراجعة الأساسيات	حل اختبار ذاتي وتحديد الفجوات.
22	اختيار مسار ومشروع	تحديد الهدف ونطاق المشروع.
23	تنفيذ المشروع	سجل خطوات ونتائج قابلة لإعادة التحقق.
24	تقرير نهائي وعرض	تقرير ومراجعة ودروس مستفادة.

إيقاع الدراسة الأسبوعي المقترح

3 ساعات · تطبيق

مختبر عملي أو مشروع صغير مرتبط بموضوع الأسبوع.

3 ساعات · فهم

دروس وقراءة مركزة، مع تدوين المصطلحات وأسئلة الفهم.

1-2 ساعة · توثيق

تنظيم الملاحظات، وكتابة تقرير أو تحديث مشروعك.

1-2 ساعة · مراجعة

تلخيص دون النظر إلى المصدر، وحل أسئلة أو شرح المفاهيم.

قاعدة المرونة

الخطة ليست سباقًا. إذا لم تستطع شرح موضوع معين، أعد دراسته بتطبيق مختلف بدل الانتقال السريع إلى موضوع جديد. جودة الفهم أهم من عدد الساعات المسجلة.

عادات التعلم والتقييم

STUDY SYSTEM & SELF-ASSESSMENT

طريقة الدراسة تؤثر في النتيجة بقدر اختيار المواد. اجعل لكل موضوع فهمًا وتطبيقًا وتوثيقًا ومراجعة.

طريقة تعلم تمنع التشتت

1. اختر موضوعًا صغيرًا لكل جلسة بدل فتح خمسة موضوعات في الوقت نفسه.
2. اكتب سؤالًا تريد الإجابة عنه قبل مشاهدة الدرس.
3. اشرح الفكرة بكلماتك بعد الانتهاء، دون الرجوع إلى المصدر.
4. نفّذ تجربة قصيرة تثبت فهمك.
5. دوّن النتيجة وأسبابها والقيود التي لاحظتها.
6. راجع بعد يومين ثم بعد أسبوع، وحاول استرجاع المفهوم من الذاكرة.

كيف تسجل ملاحظات تقنية؟

استخدم قالبًا ثابتًا لكل مفهوم أو أداة. ذلك يجعل ملاحظاتك مفيدة عند مراجعة مشروع أو التحضير لمقابلة.

```
المفهوم:
التعريف بكلماتي:
لماذا يهم أمنيًا؟
مثال عملي:
الأمر أو الأداة ذات الصلة:
النتيجة التي ظهرت:
كيف أفسرها؟
ما الذي لا تثبته النتيجة؟
سؤال يحتاج إلى مراجعة:
```

الأخطاء الشائعة

الخطأ	البديل الأفضل
البدء بـKali دون أساس.	تعلم Linux والشبكات ثم افهم أداة واحدة في كل مرة.
حفظ الأوامر دون تفسير.	اكتب وظيفة الأمر، ومعنى الخيارات، وكيف تتحقق من المخرجات.
دراسة عدة مسارات معًا.	اختر أساسًا مشتركًا ثم نفّذ تجربة صغيرة لمسار مهني.
الاعتماد على الفيديوهات فقط.	خصص جزءًا من وقتك للتطبيق والشرح والتوثيق.
الاعتقاد أن كل تنبيه يعني هجومًا.	اجمع الأدلة، وقارن السياق، وافصل الحقيقة عن الفرضية.
الاعتقاد أن كل منفذ مفتوح ثغرة.	تعرف على الخدمة، وسبب وجودها، وإعداداتها وأثرها.

الخطأ	البديل الأفضل
التعلم دون توثيق.	حوّل كل مختبر إلى تقرير يستطيع شخص آخر فهمه.

مقياس أسبوعي لتقدمك

- [ ] هل أستطيع شرح ثلاثة مفاهيم تعلمتها بكلماتي؟
- [ ] هل أنجزت تجربة عملية يمكن إعادة تنفيذها؟
- [ ] هل فسرت النتيجة بدل نسخها فقط؟
- [ ] هل دوّنت ما لم أفهمه بعد؟
- [ ] هل راجعت موضوعًا سابقًا بدل الاكتفاء بالجديد؟

قاموس ومصادر

GLOSSARY & RESOURCES

استخدم القاموس لمراجعة المصطلحات الأساسية، ثم أجب عن أسئلة التقييم. في النهاية اختر مصدرًا مناسبًا وابدأ مسارًا تدريبيًا واحدًا.

قاموس مختصر

المصطلح	شرح مبسط
Asset	أصل له قيمة يجب حمايته.
Attack Surface	نقاط وواجهات يمكن أن يحاول أحد التفاعل معها.
Authentication	التحقق من الهوية.
Authorization	تحديد ما الذي يسمح للهوية بفعله.
Backup	نسخة تستخدم للاستعادة بعد فقد أو تلف البيانات.
CIA Triad	السرية وسلامة البيانات والتوافر.
Cookie	بيانات صغيرة يخزنها المتصفح.
DNS	نظام سجلات أسماء النطاقات.
EDR	مراقبة واكتشاف واستجابة على نقاط النهاية.
Exploit	طريقة للاستفادة من ضعف أمني.
Firewall	ضوابط تتحكم في حركة الشبكة.
Hash	قيمة ناتجة عن خوارزمية تجزئة.
HTTP	بروتوكول الويب للطلبات والاستجابات.
Incident Response	التعامل المنظم مع الحوادث الأمنية.
IP Address	عنوان منطقي لواجهة شبكة.
Least Privilege	منح أقل صلاحيات لازمة.
Log	سجل أحداث من نظام أو تطبيق.
MFA	مصادقة متعددة العوامل.
Patch	تحديث يصلح مشكلة أو يحسن مكوّنًا.

المصطلح	شرح مبسط
Port	رقم يستخدم لتوجيه بيانات النقل إلى الخدمة المناسبة.
Process	برنامج قيد التنفيذ.
Risk	احتمال وأثر حدث ضار في سياق محدد.
SIEM	تجميع وربط وتحليل أحداث أمنية.
Threat	عامل أو حدث قد يسبب ضررًا.
TLS	بروتوكول لحماية الاتصال.
Vulnerability	ضعف قد يؤثر في أمن النظام.
Zero Trust	نهج لا يمنح الثقة لمجرد موقع المستخدم داخل الشبكة.

أسئلة مراجعة نهائية

1. ما الفرق بين RAM وSSD؟

أجب بكلماتك، ثم تحقق من إجابتك في الفصل ذي الصلة.

2. ما الفرق بين IP وMAC؟

أجب بكلماتك، ثم تحقق من إجابتك في الفصل ذي الصلة.

3. ما وظيفة DNS، ومتى تحتاج إلى استعلام جديد؟

أجب بكلماتك، ثم تحقق من إجابتك في الفصل ذي الصلة.

4. ما الفرق بين TCP وUDP؟

أجب بكلماتك، ثم تحقق من إجابتك في الفصل ذي الصلة.

5. ما وظيفة المنفذ في الاتصال؟

أجب بكلماتك، ثم تحقق من إجابتك في الفصل ذي الصلة.

6. ما الفرق بين Program وProcess وService؟

أجب بكلماتك، ثم تحقق من إجابتك في الفصل ذي الصلة.

7. ما الفرق بين Authentication وAuthorization؟

أجب بكلماتك، ثم تحقق من إجابتك في الفصل ذي الصلة.

8. اشرح السرية وسلامة البيانات والتوافر بمثال لكل واحدة.

أجب بكلماتك، ثم تحقق من إجابتك في الفصل ذي الصلة.

9. ما الفرق بين Threat وVulnerability وRisk؟

أجب بكلماتك، ثم تحقق من إجابتك في الفصل ذي الصلة.

10. لماذا لا يعني وجود منفذ مفتوح أن النظام مخترق؟

أجب بكلماتك، ثم تحقق من إجابتك في الفصل ذي الصلة.

11. ما الفرق بين Hashing وEncryption وEncoding؟

أجب بكلماتك، ثم تحقق من إجابتك في الفصل ذي الصلة.

12. لماذا يجب اختبار استعادة النسخة الاحتياطية؟

أجب بكلماتك، ثم تحقق من إجابتك في الفصل ذي الصلة.

13. ما الذي ينبغي أن يتضمنه تقرير اختبار أمني؟

أجب بكلماتك، ثم تحقق من إجابتك في الفصل ذي الصلة.

14. كيف تتعامل مع تنبيه أمني دون افتراض أن الهجوم وقع بالفعل؟

أجب بكلماتك، ثم تحقق من إجابتك في الفصل ذي الصلة.

15. ما المشروع الذي ستنفذه بعد قراءة هذا الدليل؟

أجب بكلماتك، ثم تحقق من إجابتك في الفصل ذي الصلة.

مصادر موثوقة للتوسع

ابدأ بمصدر واحد في كل مرحلة. قد تتغير واجهات المنصات أو محتويات المسارات؛ راجع صفحاتها الرسمية لمعرفة الوضع الحالي ومتطلبات التسجيل.

1. Cisco Networking Academy · Introduction to Cybersecurity

مدخل منظم إلى المفاهيم الأساسية والمخاطر والحماية، ويتوفر بلغات متعددة منها العربية.

netacad.com/ar/courses/introduction-to-cybersecurity

2. TryHackMe · Pre Security

مسار للمبتدئين يربط أساسيات الكمبيوتر والبرمجة والشبكات والويب بمقدمة في الأمن.

tryhackme.com/path/outline/presecurity

3. OverTheWire · Bandit

تدريب تدريجي على أساسيات Linux والطرفية وحل المشكلات.

overthewire.org/wargames/bandit/

4. PortSwigger Web Security Academy

شروحات ومختبرات تفاعلية لأمن تطبيقات الويب. نفّذ التمارين داخل المختبرات المصممة لهذا الغرض.

portswigger.net/web-security

5. OWASP Top 10:2025

مرجع توعوي لمخاطر أمن تطبيقات الويب المهمة، ويجب استخدامه لفهم أسباب الضعف ومعالجتها لا لحفظ الأسماء فقط.

top10.owasp.org/2025/

6. NIST Cybersecurity Framework 2.0

إطار مرجعي لتنظيم جهود إدارة مخاطر الأمن السيبراني عبر وظائف الحوكمة والتحديد والحماية والاكتشاف والاستجابة والتعافي.

nist.gov/cyberframework

ابدأ بخطوة واحدة

اختر موضوعًا من أول ثلاثة فصول، وطبّقه اليوم. اكتب ما فهمته، وما الذي لاحظته، وما الذي لا تزال تحتاج إلى التحقق منه. هذا الأسلوب البسيط، المتكرر، هو ما يحول دراسة الأمن السيبراني إلى مهارة عملية.

LEARN · PRACTICE · EXPLAIN · REPEAT

إعداد تعليمي للمبتدئين · تمت مراجعة روابط الموارد الرسمية في أكتوبر 2026. تختلف التفاصيل والإعدادات باختلاف الأنظمة والمنصات. التزم دائمًا بالنطاق المصرح به عند التدريب.